

REPORT TECNICO: ANALISI MALWARE & TRIAGE

IOC

Configurazione Laboratorio FlareVM e Analisi Comparativa OSINT

Autore:	Leandro Ancona	Data:	3 Giugno 2026
Corso:	Cybersecurity & Ethical Hacking (Epicode)	Ambiente:	FlareVM v11 (Windows 10 Isolated)

1. Obiettivi del Laboratorio

Il presente documento descrive le attività svolte per la messa in sicurezza dell'ambiente di analisi, la simulazione di tecniche di persistenza locali mediante la manipolazione del Registro di Sistema di Windows, e l'attività di triage statico/OSINT effettuata su tre campioni di malware estratti dal repository locale.

CONCETTO DIDATTICO: PERCHÉ L'ISOLAMENTO?

Nel malware analysis, l'isolamento della macchina virtuale (Host-Only network) è il requisito fondamentale per evitare fughe di codice malevolo o comunicazioni non controllate verso l'esterno, proteggendo la rete aziendale o domestica ospitante (Host).

2. Setup dell'Ambiente ed Esecuzione dello Snapshot

Prima di manipolare i file eseguibili o eseguire script potenzialmente dannosi, è stata verificata la corretta configurazione di **FlareVM**. Lo stato iniziale pulito è stato congelato creando un'apposita istantanea (**Snapshot "Clean"**) all'interno del software di virtualizzazione.

Comando di ripristino (Rollback): Al termine delle attività di analisi distruttiva o esecuzione, lo stato della macchina viene resettato forzatamente eliminando le modifiche accumulate nello "Stato Attuale", garantendo un riavvio incontaminato per le analisi successive.

3. Attività: Simulazione di Persistenza Manuale

Per comprendere i meccanismi di avvio automatico abusati dai malware, è stata simulata una persistenza manuale utilizzando l'editor del registro di Windows (`regedit`).

Dettaglio Operativo e Comandi:

- Apertura del prompt dei comandi o della finestra di esecuzione tramite la combinazione di tasti `Windows + R`.
- Esecuzione del comando: `regedit` per avviare l'interfaccia di gestione del database di configurazione.
- Navigazione fino alla chiave specifica associata al profilo utente corrente:
`HKEY_CURRENT_USER\Software\Microsoft\Windows\CurrentVersion\Run`
- Creazione di un nuovo **Valore Stringa (REG_SZ)** denominato convenzionalmente `TestPersistenza`.

5. Configurazione del payload puntando a un binario legittimo per simulare l'attacco senza compromettere il sistema: `C:\Windows\System32\notepad.exe`.

SPIEGAZIONE TECNICA: CHIAVI RUN

Le chiavi di registro sotto il percorso `\CurrentVersion\Run` vengono lette automaticamente dal processo di login di Windows (`userinit.exe`). Ogni stringa presente al loro interno viene eseguita nel contesto di sicurezza dell'utente loggato, garantendo al malware l'esecuzione automatica ad ogni riavvio.

4. Estrazione degli Hash e Triage (HashMyFiles)

I campioni di malware scelti sono stati scompattati all'interno della cartella protetta `C:\Users\Flare\Desktop\malware`. Utilizzando il tool di sistema **HashMyFiles**, sono state calcolate le impronte digitali (funzioni di hashing crittografico) necessarie per l'identificazione univoca senza esecuzione.

Nome File	Hash MD5	Hash SHA-256 (Identificativo Univoco)
Annabelle.exe	782705b242d2c1921ef2f6bb a5f68928	716335ba5cd1e7186c40295b199190e2b6655e4 8f1c1cbe12139ba67faa5e1ac
Derialock.exe	7d80230df68ccba871815d68 f016c282	4f5bff64160044d9a769ab277ff85ba954e2a2 e182c6da4d0672790cf1d48309
RedEye.exe	b2d0542660eefeac0e8895c65 2e89a6c	9ac9f207060c28972ede6284137698ce076965 c7ad98ab320605d23362305

5. Ricerca ed Intelligence OSINT su VirusTotal

Gli hash SHA-256 estratti sono stati inseriti sulla piattaforma di Threat Intelligence **VirusTotal** per esaminare i comportamenti registrati all'interno delle Sandbox globali (schede *Behavior* e *Relations*).

Malware	Detection Ratio	Connessioni di Rete / Dominio C2	Indicatori di Registro (IOC)
Annabelle	61 / 71	myip.dnsomatic.com (HTTP)	Modifica impostazioni di sicurezza locali e policy di sistema.
Derialock	58 / 72	N/D (Esecuzione locale offline)	HKLM\SOFTWARE\Microsoft\Windows NT\CurrentVersion\Image File Execution Options
RedEye	55 / 70	Connessioni IP multiple (AS8075)	HKCU\Software\Microsoft\Windows\CurrentVersion\Run (Persistenza attiva)

6. Analisi Critica dell'Intelligenza Artificiale (LLM)

L'ultima fase prevede la valutazione critica delle risposte fornite dai modelli di intelligenza artificiale applicati al triage dei malware.

Punti di Forza dell'Approccio Automatizzato:

- **Efficienza e Velocità:** L'AI permette l'estrazione immediata degli indicatori noti e la correlazione con le tattiche del framework MITRE ATT&CK senza impiegare ore nell'analisi statica manuale del codice.
- **Sintesi dei dati complessi:** Organizza i log destrutturati delle sandbox di VirusTotal (es. migliaia di chiamate API) in formati leggibili e tabelle strutturate.

Limiti Tecnici Evidenziati (Mancanza di Completezza):

- **Fragilità degli indicatori statici:** L'analisi basata puramente sull'hash fallisce se l'attaccante applica tecniche di offuscamento o modifica un solo byte del codice (tecnica del polimorfismo), generando un hash completamente differente (*effetto valanga*).
- **Assenza del contesto locale:** L'AI non può prevedere se il malware fallirà la sua esecuzione all'interno del nostro specifico laboratorio a causa di contromisure locali o reti simulate (es. FakeNet-NG che blocca la risoluzione di `dnsomatic.com`).

VERDETTO DELL'ANALISTA

L'ausilio dell'AI e delle piattaforme OSINT è da considerarsi **parzialmente completo**. Fornisce un triage iniziale eccellente, ma deve essere obbligatoriamente integrato con l'**Analisi Dinamica Attiva** sul campo, monitorando i processi in tempo reale con tool come ProcMon e Regshot all'interno dell'ambiente controllato FlareVM.